

최종 발표 · 팀 프로젝트

ISMS-P 인증 질의응답 에이전트

264쪽 안내서와 190행 통계표를 한 번에 묻는 AI 에이전트

LangGraph · RAG · Text2SQL

실무자는 성격이 다른 두 자료를 계속 오갑니다

■ 서술형 자료

인증기준 안내서 · 264쪽

- 기준의 의미와 이행 방법
- 심사 관점과 사례
- "어떻게 해야 하나요?" 형태의 질문

■ 수치형 자료

결함 통계표 · 190행

- 통제항목별 결함 건수
- 분야별 합계와 순위
- "몇 건인가요?" 형태의 질문

- 질문마다 어느 자료를 봐야 하는지부터 사람이 판단해야 한다

일반 챗봇으로는 왜 안 되는가

일반 챗봇

표의 숫자를 그럴듯하게 지어냅니다.

"접근 권한 검토 결함은 약 15건입니다" — 근거 없음

문서 검색만 붙인 방식

264쪽에서 문단은 찾지만
집계·순위는 계산하지 못합니다.

"결함이 가장 많은 분야는?" — 답변 불가

필요한 것

질문 유형을 먼저 판별해 알맞은 자료로 보내고,
생성된 답을 근거와 대조해 검증하는 에이전트

질문을 먼저 분류해 세 갈래로 보냅니다

모든 질문에 같은 방식으로 답하지 않는 것 — 이것이 이 에이전트의 뼈대입니다

VECTOR · 문서 검색

"어떻게 이행하나요?"

PDF 안내서를 벡터 검색
문장을 좌표로 바꿔 뜻이 가까운 것을 찾기

DATABASE · 표 조회

"결함이 몇 건인가요?"

CSV를 Text2SQL로 조회
사람 말을 SQL로 번역해 표를 직접 계산

GENERAL · 바로 답변

"ISMS-P가 뭐야?"

자료 조회 없이 즉시 응답
인사 · 사용법 · 고수준 소개

- 세 갈래가 끝난 뒤에는 모두 같은 검증 단계를 거칩니다
답이 근거와 맞는지 확인하고, 통과한 답만 사용자에게 보여줍니다

ISMS-P 인증기준 안내서 264쪽

ISMS-P 란?

정보보호 및 개인정보보호 관리체계 — 기업·기관이 정보와 개인정보를 안전하게 지킬 **체계를 제대로 갖췄는지 국내 기준에 따라 심사받는 인증 제도**입니다.

인증을 받으려면 정해진 **인증기준을 항목별로 충족**해야 하고, 심사에서 못 지킨 부분은 '**결함**'으로 기록됩니다. → 이 안내서가 그 인증기준을 풀어 쓴 공식 문서이고, 다음 장의 결함 통계표가 심사 결과입니다.

출처

- 「정보보호 및 개인정보보호 관리체계(ISMS-P) 인증기준 안내서」
- 개인정보보호위원회 발간 · 2023년 11월
- 발간등록번호 11-17903650-100016-14
- 264쪽 · 약 7MB

활용 목적

- 기준의 의미와 이행 방법
- 심사 관점과 사례
- 표로는 답할 수 없는 서술형 근거

1,855개

생성된 벡터 조각

3,072차원

text-embedding-3-large

상위 3건

검색 결과 · 유사도 임계값 0.5

출처·페이지

답변에 근거 위치 표기

성격이 다른 표 2개

파일	출처	규모	활용 목적
<code>isms_items.csv</code> 인증기준 항목표	ISMS-P 관리체계 세부 점검 항목 (안내서 기반 정리)	65행 6컬럼	특정 행을 정확히 짚는 조회 분야 · 분야명 · 항목번호 · 항목명 · 상세내용 · 주요 확인 사항
<code>isms_defects.csv</code> 결함 통계표	한국인터넷진흥원(KISA) ISMS·PIMS 연도별 결함 현황	190행 4컬럼	개수 · 합계 · 순위 · 비교 통제분야 · 통제영역 · 통제항목 · 결함수

예시 — 인증기준 항목표

분야명 관리체계 기반 마련 · 항목번호 1.1.1 · 항목명 경영진의 참여

발표장 대비 장치

환경변수 하나로 **Supabase ↔ 로컬 CSV** 전환
네트워크 없이도 데모가 동작합니다

결함은 두 분야에 몰려 있습니다

174건

기록된 총 결함

190개

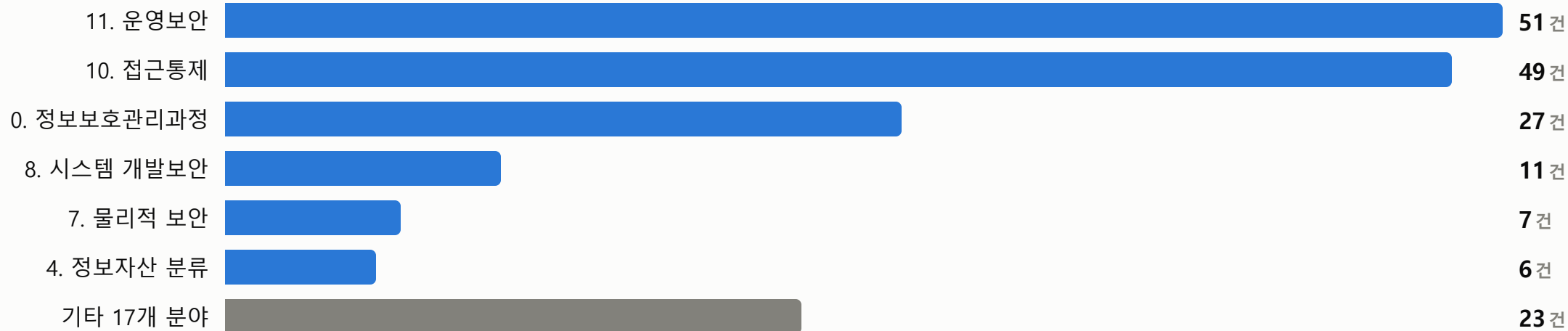
통제항목 (23개 분야)

138개

결함 0건인 항목

19건

최다 항목 (보안 시스템 운영)



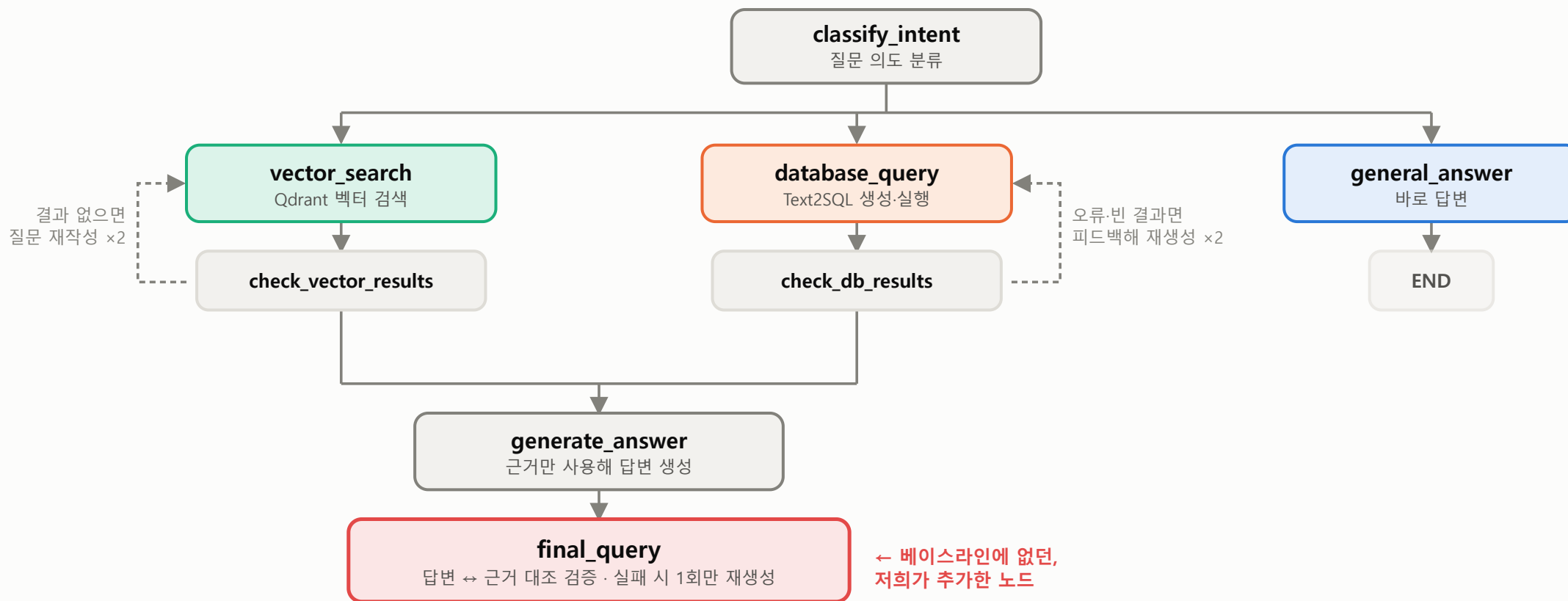
통제분야별 결함 합계 · 단위: 건 — 상위 6개 분야와 나머지 17개 분야 합계.

데모 질문은 이보다 한 단계 세분화된 통제영역 단위로 묻습니다 (예: 10.4 접근통제 영역 30건). [표로 보기](#)

4. 시스템 구조

LangGraph 노드 7개와 조건부 분기

LangGraph = AI 작업 흐름을 그래프로 그리는 도구 · 노드는 작업 단계, 화살표는 다음에 할 일



8가지 고도화 — 전부 오답에서 출발했습니다

수업 베이스라인

분류 → 검색 → 답변 생성

생성된 답을 그대로 사용자에게 전달



최종 시스템

답변 검증 노드 규칙 우선 라우팅 고정 SQL 동물·범위 명시

JOIN 제거 상태 초기화 초안 비공개 설정 외부화

- 설계로 미리 넣은 것이 아니라 테스트하다 발견한 오답을 고친 결과
- 다음 3장에서 대표 사례 3가지를 문제 → 원인 → 해결 순으로 보여드립니다

근거에 없는 말을 걸러내는 노드를 만들었습니다

문제

모델이 근거에 없는 내용을 지어내도 그대로 사용자에게 전달됩니다.

근거에 없던 법적 의무·수치가 답변에 섞여 나옴

해결 — final_query 노드 신설

질문 · 검색 근거 · 생성된 답변을 나란히 놓고
답이 근거로 확인되는지 판정합니다.

실패하면 구체적 피드백을 만들어 **1회만** 재생성 (무한 루프 방지)

- 검증 항목: 항목번호·수치가 근거와 일치하는가, 없는 의무를 추가하지 않았는가, 출처·페이지가 실제 근거와 맞는가
- 답변을 만드는 일과 근거와 대조하는 일을 분리한 것이 핵심

표에 있는 걸 문서에서 찾고 있었습니다

문제

LLM 단독 분류가 **명백한 표 조회를 문서 검색으로 보냈습니다.**

"경영진의 참여 **상세내용**은?" → 문서 검색 → 근거 부족 → 답변 거부

해결 — LLM 호출 전에 규칙으로 먼저 판별

CSV 컬럼명과 실제 값으로 결정적으로 거릅니다.

애매한 질문만 LLM 분류로 넘김

- **컬럼명이 나오면 무조건 DB**

상세내용 · 주요 확인사항 · 항목번호 · 결함수 ...

- **CSV에 실제 있는 분야명·항목명을 대조**

그 값이 있고 "어떻게 · 방법 · 사례" 같은 설명 요구가 없으면 DB로

- **결과: 표 질문은 표로, 설명 질문은 문서로 안정적으로 갈라짐**

"가장 적은 항목"의 정답은 하나가 아니었습니다

문제

같은 질문에 답이 3번 다 달랐습니다.

- ① LLM이 매번 다른 SQL 생성
- ② 그 SQL이 **LIMIT 1**로 한 행만 가져옴

해결 — 고정 SQL + 두 범위 모두 제시

최소·최대 질문은 LLM에게 말기지 않고 고정 쿼리로 처리.

동물 개수를 세고, 대표 항목 10개만 예시로 제시

138개 동물

0건 포함 기준 최소 — 결함 0건 항목

21개 동물

0건 제외 기준 최소 — 결함 1건 항목

1개?

베이스라인이 답하던 개수 — 틀린 답

질문이 0건을 포함하는지 모호하므로, 두 범위를 구분해 함께 답합니다.

5. 실시간 데모

데모 앱 사이드바의 준비된 질문 8가지

팀원이 만든 Streamlit 앱 — 사이드바 버튼을 클릭만 하면 실행됩니다

🗣️ 일반 대화

1 안녕하세요.

자료 조회 없음

2 오늘 날씨 어때?

범위 밖 → 역할 안내

🔍 가이드라인 문서 검색

3 ISMS-P 인증 기준 1.1.1 항목의 **주요 확인 사항**은? ※ 실제로는 표 조회

isms_items 1행

4 비밀번호 작성 규칙에 대한 가이드라인을 알려줘.

출처·페이지 표기

5 경영진 참여 요건이 뭐야?

출처·페이지 표기

📊 결함 통계 DB 검색

6 가장 결함이 많이 발생한 **통제영역 Top 3**를 알려줘.

30 · 27 · 15건

7 결함 발생 건수가 **20건 이상**인 통제영역은 어디야?

2곳

8 **10.4 접근통제 영역**의 결함 건수는 몇 개야?

30건

📄 직접 입력 — 슬라이드 12를 보여줄 질문 (사이드바에 없음)

9 결함이 **가장 적게 발생한 항목**은 무엇이고 몇 건이야? ★ 하이라이트

138개 / 21개 동률

🔴 표 조회 (Text2SQL) 🟢 문서 검색 (RAG) 🟡 일반 대화 — 색은 에이전트가 실제로 타는 경로 기준

실시간 데모

질문 8가지 · 세 경로 모두 확인

배운 것

- **라우팅이 답변 품질의 절반**

좋은 모델을 써도 엉뚱한 자료를 뒤지면 답이 나오지 않습니다

- **정확해야 하는 계산에는 LLM에게 자유를 주지 않는다**

최소·최대·순위는 고정 쿼리로 — 같은 질문엔 같은 답이 나와야 합니다

- **생성한 답을 근거와 대조하는 단계가 필요하다**

만드는 일과 검증하는 일을 분리하니 지어낸 내용이 줄었습니다

8가지 개선은 모두 직접 질문을 던져보다 발견한 오답에서 출발했습니다.

감사합니다